

1. Identificacion del contrato

Proposito	Banco/boveda: los usuarios depositan ETH y retiran segun su saldo.
Actores	Usuarios (deposit/withdraw), Owner (declarado, sin uso).
Flujo de fondos	ETH entra por deposit()/receive(); sale por withdraw().

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	Reentrancy clasica en withdraw() Root: Orden incorrecto: interaccion antes del efecto (no se respeta Checks-Effects-Interactions).	withdraw() hace el call de ETH ANTES de restar balances[msg.sender]. El receptor malicioso reentra en withdraw() con el saldo aun intacto. Vector: Contrato atacante con fallback que reentra withdraw() y drena todo el ETH del banco (patron tipo The DAO).	Critical	SWC-107	SC08:2026 Reentrancy
2	Variable owner sin uso Root: Variable declarada y no implementada.	owner se asigna en el constructor pero no se utiliza en ninguna funcion. Vector: N/A (codigo muerto que puede inducir falsa sensacion de control).	Low	N/A	SC02:2026 Business Logic Errors

3. Analisis de logica de negocio

Aparte de la reentrancy, la logica de saldos es correcta; el unico actor de riesgo es un retirante malicioso reentrante.
--

6. Benchmark metrics

2	1	0	0	1	0.95	0.95	1.00	40	82
Total	Critical	High	Medium	Low	Confidence	Precision	Coverage	Time (s)	Risk

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).